

MERIDIAN HEALTH GROUP

Zero Trust Identity & Access Management

IAM Lab Implementation Report

Microsoft Entra ID · Zero Trust Architecture · HIPAA Security Rule Alignment

Document Type	IAM Lab Implementation Report — Zero Trust Architecture
Document ID	MHG-IAM-RPT-001
Classification	CONFIDENTIAL — Internal Use Only
Version	v1.0 (Initial Release)
Effective Date	June 2026
Review Cycle	Quarterly — Next Review: September 2026
Prepared By	Maximilian Rivera — Information Security Analyst
Reviewed By	CISO, Meridian Health Group
Approved By	Vice President, Information Technology
Microsoft Tenant	f8cdef31-a31e-4b4a-93e4-5f571e91255a
License Tier	Microsoft Entra ID Free (P1/P2 roadmap documented herein)
Framework Alignment	NIST SP 800-207 Zero Trust Architecture; HIPAA Security Rule 45 CFR §164; NIST CSF 2.0; CIS Controls v8

Table of Contents

Executive Summary

This report documents the design, configuration, and implementation of a Zero Trust Identity and Access Management (IAM) environment for Meridian Health Group (MHG), a mid-sized healthcare organization subject to HIPAA Security Rule requirements. The lab was built using Microsoft Entra ID (formerly Azure Active Directory) and is aligned to NIST Special Publication 800-207 (Zero Trust Architecture), NIST Cybersecurity Framework (CSF) 2.0, and CIS Controls v8.

The Zero Trust model operates on the principle of never trust, always verify — eliminating implicit trust in any identity, device, or network segment. This implementation establishes a layered identity security posture through enforced multi-factor authentication, role-based access control grounded in the principle of least privilege, Conditional Access policy enforcement, and a documented Joiners-Movers-Leavers (JML) lifecycle workflow.

Key Outcomes

10 user accounts provisioned across 6 departments · 10 security groups configured with Dynamic and Assigned membership · 7 Conditional Access policies documented (5 active, 1 report-only, 1 planned) · RBAC applied with least privilege across all Microsoft 365 workloads · 6 security findings identified with prioritized remediation roadmap · Quarterly access review cycle established with full certification records

Security Defaults are currently active as the baseline MFA enforcement mechanism for all member accounts, as the organization is operating on the Entra ID Free tier. A prioritized licensing roadmap is documented in Section 10, with a recommended path to Entra ID P1 (Conditional Access) and P2 (Identity Protection and PIM) to achieve full Zero Trust maturity.

1. Introduction & Scope

1.1 Purpose

This document serves as the formal technical record for the Meridian Health Group Zero Trust IAM implementation. It is intended to provide auditors, leadership, and technical stakeholders with a comprehensive view of the identity security controls deployed, the rationale behind design decisions, and the roadmap for achieving full Zero Trust maturity.

1.2 Scope

The scope of this engagement covers all identity and access management controls within the Meridian Health Group Microsoft Entra ID tenant. Specifically, this implementation addresses:

- All user and guest accounts within the Entra ID tenant (Tenant ID: f8cdef31-a31e-4b4a-93e4-5f571e91255a)
- Security group design and membership management
- Role-based access control (RBAC) using Entra ID built-in and custom roles
- Authentication policies — Security Defaults and Conditional Access
- Identity lifecycle management — Joiners, Movers, and Leavers (JML) workflow
- Quarterly access review and certification procedures
- Conditional Access policy architecture (implemented and roadmap)

Out of scope for this engagement: Endpoint security configuration (Intune MDM), on-premises Active Directory, application development security, and network perimeter controls.

1.3 Regulatory & Framework Alignment

This implementation is designed to satisfy the following regulatory and framework requirements:

Framework / Regulation	Applicable Controls	IAM Coverage
HIPAA Security Rule (45 CFR §164)	§164.308(a)(3) Workforce Security; §164.312(a)(2) User Auth; §164.312(d) Person Authentication	MFA enforcement, RBAC, access controls, audit logging
NIST SP 800-207 — Zero Trust Architecture	ZTA Pillars: Identity, Device, Network, Application, Data	Identity pillar fully addressed; Device pillar in progress (Intune)
NIST CSF 2.0	PR.AC (Access Control); PR.AA (Authentication); DE.CM (Monitoring)	Conditional Access, MFA, sign-in log monitoring
CIS Controls v8	CIS Control 5 (Account Management); CIS Control 6 (Access Control Mgmt)	User provisioning, RBAC, privilege management, access reviews
SOC 2 Type II (Planned)	CC6.1 (Logical Access); CC6.2 (Auth); CC6.3 (Least Privilege)	Role assignments, access reviews, JML workflow

2. Organization Overview — Meridian Health Group

Meridian Health Group (MHG) is a mid-sized healthcare network operating three outpatient clinics and one administrative headquarters in central Florida. The organization employs approximately 200 staff across clinical, operational, administrative, and technical departments, and handles Protected Health Information (PHI) for an estimated 45,000 active patients annually.

2.1 Technology Environment

- Cloud Platform: Microsoft 365 (Exchange Online, Teams, SharePoint Online, OneDrive for Business)
- Identity Provider: Microsoft Entra ID (Free tier; P1/P2 upgrade roadmap in Section 10)
- Endpoint Management: Microsoft Intune (enrollment in progress)
- Security Operations: Microsoft Defender for Endpoint (licensed); Microsoft Sentinel (evaluation)
- EHR System: ClearPath Health — integrated via B2B federation (vendor access controlled)
- On-Premises Infrastructure: Windows Server 2022 domain (Entra ID Connect roadmap)

2.2 IAM Personas

The following personas represent the primary identity archetypes within the Meridian Health Group IAM environment. Each persona has distinct access requirements, risk profiles, and authentication controls:

Persona	Representative User	Department	Risk Level	Access Profile
IT Administrator	Marcus Chen	Information Technology	CRITICAL	Global Admin — break-glass, privileged
Security Analyst	Priya Okafor	Information Security	MEDIUM	Security Reader + Operator, SIEM access
Clinical Director	Dr. Sandra Walsh	Clinical Operations	HIGH	PHI access via SharePoint & Teams
HR Manager	James Thornton	Human Resources	MEDIUM	User Admin (scoped), HR docs
Finance Analyst	Elena Vasquez	Finance	MEDIUM	Finance SharePoint, Power BI
Executive	Robert Kim	Executive	HIGH	Global Reader, executive briefings
Compliance Officer	Tamara Ellis	Compliance	MEDIUM	Compliance Admin, Audit Logs
Help Desk Tech	David Park	Information Technology	LOW	Help Desk Admin — scoped to non-privileged
Service Account	SVC-AuditBot	Information Security	MEDIUM	Certificate-based auth, no interactive login
External Vendor	EXT-ClearPath	Vendor (B2B Guest)	HIGH	SharePoint vendor portal only — B2B guest

3. Zero Trust Architecture Framework

The Zero Trust Architecture (ZTA) implemented for Meridian Health Group is based on the NIST Special Publication 800-207 framework, which defines seven tenets of Zero Trust. This implementation prioritizes the Identity pillar as the foundational control plane — consistent with Microsoft's Zero Trust model and CISA guidance on identity-centric security.

3.1 Zero Trust Tenets Applied

Tenet 1 — Verify Explicitly: All access requests are authenticated using MFA (enforced via Security Defaults and Conditional Access). No request is trusted based on network location or device type alone.

Tenet 2 — Use Least Privileged Access: Role assignments follow the principle of least privilege. No user holds more permissions than required for their job function. Privileged roles are documented with justification and reviewed quarterly.

Tenet 3 — Assume Breach: Audit logging is enabled for all sign-in events, role changes, and policy modifications. Security alerts are routed to the Security Operations team for review. Conditional Access policies limit blast radius through geo-restriction and device compliance enforcement.

Zero Trust Identity Pillar — Microsoft Entra ID Control Points

Authentication: MFA via Security Defaults (all users) | Authorization: RBAC with least privilege + Conditional Access | Threat Detection: Sign-in risk policies (planned, P2) | Governance: Quarterly access reviews + JML workflow | Audit: Entra ID audit logs + Compliance Center Purview

3.2 Identity as the Control Plane

In a perimeter-less environment — which MHG operates given its cloud-first Microsoft 365 deployment — identity becomes the primary security boundary. Every access request to SharePoint, Teams, Exchange, and administrative portals is evaluated against Entra ID policies before access is granted. This replaces the traditional VPN-centric model with explicit, policy-driven access decisions.

3.3 Technology Stack

- Identity Provider: Microsoft Entra ID — tenant ID f8cdef31-a31e-4b4a-93e4-5f571e91255a
- Authentication: Security Defaults (MFA) + Conditional Access policies (P1 roadmap)
- Authorization: Entra ID built-in roles + Security Groups for M365 workload permissions
- Governance: Access reviews (manual quarterly cycle; automated reviews planned with P2)
- Threat Detection: Microsoft Defender for Endpoint + Sentinel integration (evaluation)
- Device Management: Microsoft Intune — enrollment in progress for privileged users

4. Identity & Access Management Implementation

4.1 Tenant Configuration

The MHG Entra ID tenant was configured with the following baseline settings to establish a secure identity foundation:

- **Security Defaults:** Enabled — enforces MFA for all users, blocks legacy authentication, and requires MFA for privileged operations on all Microsoft portals.
- **Password Protection:** Entra ID Smart Lockout configured with threshold of 10 failed attempts. Custom banned password list includes MHG-specific terms.
- **Audit Logging:** Sign-in logs, audit logs, and provisioning logs retained for 30 days (Free tier) with export to Compliance Center for extended retention.
- **External Collaboration:** B2B collaboration enabled for approved vendor domains only. Guest access restricted — no tenant-wide guest access to Microsoft 365 Groups.
- **User Registration Policy:** Users cannot register applications without IT approval. App consent policy requires admin consent for all applications accessing tenant data.

4.2 User Provisioning

Ten accounts were provisioned within the MHG tenant representing the full spectrum of employee and non-employee identity types. All accounts follow MHG's UPN convention: [firstname.lastname]@meridianhealthgroup.org. Account provisioning follows a documented Joiner workflow (see Section 7).

#	Display Name	UPN	Department	Account Type	MFA	Status
1	Marcus Chen	m.chen@meridianhealthgroup.org	IT	Member	✓	Active
2	Priya Okafor	p.okafor@meridianhealthgroup.org	InfoSec	Member	✓	Active
3	Dr. Sandra Walsh	s.walsh@meridianhealthgroup.org	Clinical	Member	✓	Active
4	James Thornton	j.thornton@meridianhealthgroup.org	HR	Member	✓	Active
5	Elena Vasquez	e.vasquez@meridianhealthgroup.org	Finance	Member	✓	Active
6	Robert Kim	r.kim@meridianhealthgroup.org	Executive	Member	✓	Active
7	Tamara Ellis	t.ellis@meridianhealthgroup.org	Compliance	Member	✓	Active
8	David Park	d.park@meridianhealthgroup.org	IT	Member	✓	Active
9	SVC-AuditBot	svc.auditbot@meridianhealthgroup.org	InfoSec	Service	N/A	Active
10	EXT-ClearPath	ext.clearpath@clearpath-health.com	Vendor	Guest	✓	Active

4.3 Security Group Design

Security groups serve as the primary mechanism for access policy targeting in Meridian Health Group's Entra ID environment. Groups are used to assign Conditional Access policies, SharePoint permissions, and Microsoft 365 licensing. The principle of group-based access management replaces direct user-to-resource assignments, enabling scalable, auditable access control.

- **SG-ITAdmins:** Marcus Chen, David Park — Targets CA-003 (compliant device enforcement for admin portals)

- SG-SecurityOps: Priya Okafor, SVC-AuditBot — Targets CA-003 and CA-004 (geo-restriction)
- SG-ClinicalStaff: Dr. Sandra Walsh — PHI access to Clinical SharePoint and Teams channels; CA-001 + CA-005
- SG-HRPersonnel: James Thornton — User Administrator role and HR document library access
- SG-FinanceTeam: Elena Vasquez — Power BI dashboards and Finance SharePoint access
- SG-Executives: Robert Kim — Global Reader, compliant device required (CA-003)
- SG-Compliance: Tamara Ellis — Compliance Admin + Audit Log Reader, geo-restricted (CA-004)
- SG-AllStaff: Dynamic group (all member accounts) — Baseline CA-001 (MFA) and CA-002 (block legacy auth)
- SG-ExternalVendors: EXT-ClearPath — B2B guests, CA-001, CA-004, CA-006 (Terms of Use)
- SG-ServiceAccounts: SVC-AuditBot — CA-007 blocks all interactive logins for service principals

4.4 RBAC Implementation — Least Privilege

Role assignments follow a strict least-privilege model. Each role assignment is documented with a business justification and reviewed on a quarterly cycle. The following principles were applied:

- No user holds Global Administrator access except the designated IT Infrastructure Admin (Marcus Chen). This role is flagged for conversion to PIM just-in-time activation in Q3 2026.
- Privileged roles (Global Admin, User Administrator, Compliance Admin) are assigned only where the specific job function requires administrative capabilities.
- Read-only roles (Security Reader, Directory Readers, Global Reader, Audit Log Reader) are used for all oversight and monitoring functions — no write access is granted for monitoring purposes.
- Service accounts hold the minimum role required for their function (Security Reader for AuditBot). Certificate-based authentication is enforced; no interactive sign-in is permitted.
- External vendor (B2B guest) holds no Entra ID roles — access is scoped exclusively to a single SharePoint site collection via group-based permissions.

5. Authentication & MFA

5.1 Security Defaults

Microsoft Entra ID Security Defaults are currently enabled as the baseline authentication enforcement mechanism for all MHG accounts. Security Defaults provide a pre-configured set of authentication controls appropriate for organizations on the Entra ID Free tier:

- Multi-Factor Authentication (MFA): Required for all member accounts. Microsoft Authenticator app is the primary MFA method. SMS and voice call are available as fallback methods.
- Admin MFA: Required at every sign-in for all accounts holding any Entra ID administrative role — no exception for registered devices.
- Legacy Authentication Block: Security Defaults block authentication requests using protocols that cannot enforce MFA — including Basic Auth, IMAP, POP3, SMTP AUTH, and Exchange ActiveSync with older clients.
- Microsoft Portals: All access to Azure portal, Microsoft 365 Admin Center, and Entra ID Admin Center requires MFA regardless of device or location.

Important Note — Security Defaults vs. Conditional Access

Security Defaults and Conditional Access policies cannot be enabled simultaneously. When MHG upgrades to Entra ID P1, Security Defaults must be disabled and replaced with equivalent or stronger named Conditional Access policies. The Conditional Access policy inventory in Section 6 is designed as the direct replacement. No security gap will exist during the transition.

5.2 MFA Enrollment Status

As of June 2026, all 8 member accounts within the MHG Entra ID tenant have completed MFA enrollment via the Microsoft Authenticator application. MFA registration was required within 14 days of account creation for all Joiner events.

The SVC-AuditBot service account is excluded from MFA (not applicable for non-interactive service principals — certificate-based authentication is enforced instead). The EXT-ClearPath B2B guest account is required to complete MFA using their home tenant credentials, as enforced by CA-006.

5.3 Password Policy

- Entra ID enforces a minimum password length of 8 characters with complexity requirements (uppercase, lowercase, numeric, special character).
- Password expiration is disabled per NIST SP 800-63B guidance — passwords do not expire on a scheduled cycle; users are prompted to change only on detected compromise.
- Smart Lockout is configured with a threshold of 10 failed attempts. Locked accounts require IT Help Desk verification for reset (applies standard lockout to prevent brute force).
- Self-Service Password Reset (SSPR) is enabled for all member accounts — requires MFA verification before password reset is permitted.

6. Conditional Access Policies

Conditional Access (CA) is the Zero Trust policy engine within Microsoft Entra ID. CA policies evaluate every authentication request against a set of conditions — user identity, group membership, device compliance, location, application, and detected risk — and enforce access decisions in real time. Conditional Access requires Entra ID P1 or higher.

The following policy inventory represents the complete Conditional Access architecture for Meridian Health Group. Policies CA-001 through CA-004 and CA-006/CA-007 are currently enabled. CA-003 is in Report-Only mode pending Intune enrollment completion. CA-005 is planned pending P2 licensing.

Policy ID	Policy Name	Target Users	Grant Control	Status	License Req.
CA-001	Require MFA — All Users	SG-AllStaff	Require MFA	Enabled	Entra P1
CA-002	Block Legacy Authentication	All Users	Block	Enabled	Entra P1
CA-003	Compliant Device — Privileged Roles	SG-ITAdmins; Execs	MFA + Compliant Device	Report-Only	P1 + Intune
CA-004	Restrict Non-US Locations	All Users; Vendors	Block	Enabled	Entra P1
CA-005	Risk-Based MFA — Risky Sign-Ins	SG-AllStaff	MFA + PW Change (High risk)	Planned	Entra P2
CA-006	Vendor Access — Terms of Use	SG-ExternalVendors	MFA + Accept ToU	Enabled	Entra P1
CA-007	Block Interactive — Service Accounts	SG-ServiceAccounts	Block	Enabled	Entra Free

7. Joiners-Movers-Leavers (JML) Workflow

Identity lifecycle management is operationalized through a documented Joiners-Movers-Leavers (JML) workflow. This process ensures that access rights are granted promptly when employees join, updated accurately when they change roles, and revoked completely and on time when they depart. Effective JML management is a critical control for HIPAA §164.308(a)(3) Workforce Security.

7.1 Service Level Agreements (SLAs)

Event Type	SLA Target	YTD Events	SLA Met	Owner
Joiner — Account Provisioning	≤ 24 hours from start date	4	4 / 4 (100%)	IT Admin + HR Manager
Mover — Role/Access Update	≤ 48 hours from change event	2	2 / 2 (100%)	IT Admin
Leaver — Account Disable	≤ 4 hours from termination	1	1 / 1 (100%)	IT Admin (emergency: CISO)
Leaver — Full Removal & Archive	≤ 30 days from disable	1	1 / 1 (100%)	IT Admin

7.2 Joiner Process

When a new employee joins Meridian Health Group, the following steps are executed:

1. HR submits a completed New Hire Identity Request form (minimum 3 business days before start date) specifying: display name, UPN, department, job title, manager, and required group memberships.
2. IT Admin creates the Entra ID account and assigns to appropriate Security Groups based on department. No direct role assignments are made — all access is group-inherited.
3. Initial temporary password is communicated to the employee via secure channel (encrypted email or in-person). SSPR must be configured at first login.
4. MFA registration is required within the first business day. A 14-day registration deadline is enforced via Conditional Access challenge.
5. The Joiner event is documented in the JML Workflow Tracker (RBAC Matrix, JML Workflow tab) with ticket reference, provisioning date, and completion status.

7.3 Mover Process

When an employee changes roles, departments, or responsibilities:

6. The manager submits an Access Change Request via IT ticketing system, specifying current and new role, and any access additions or removals required.
7. IT Admin reviews current role assignments and removes any access no longer justified by the new job function (least privilege enforcement — no access accumulation).
8. New group memberships are assigned reflecting the updated role. SharePoint permissions update automatically via group-based access.
9. The Mover event is documented with the old and new access profile in the JML Workflow Tracker.

7.4 Leaver Process

When an employee is terminated or departs (voluntary or involuntary):

10. HR notifies IT Admin of the termination with the exact departure date and time.
11. Account is disabled immediately (≤ 4 hours) — the account is not deleted to preserve audit log continuity. All active sessions are revoked.
12. Email forwarding is configured per manager direction. OneDrive data is transferred to the manager within 14 days before account deletion.

13. All group memberships and role assignments are removed. The account is moved to a Disabled Accounts OU.
14. Full account deletion occurs after 30 days. Audit logs are retained per Compliance Center retention policies (minimum 1 year).

8. Access Reviews

Quarterly access reviews are a foundational control for HIPAA §164.308(a)(3) and CIS Control 6.5. The review process ensures that all role assignments and group memberships remain appropriate, aligned with current job functions, and consistent with the principle of least privilege.

8.1 Review Cadence & Scope

- Frequency: Quarterly (March, June, September, December)
- Scope: All Entra ID role assignments, all Security Group memberships, all guest/B2B accounts, all service accounts
- Method: Manual review using Access Review Log (RBAC Matrix, Access Review Log tab) — automated reviews require Entra ID P2 (Access Reviews feature)
- Outcome Decisions: Certified (no change), Revise (access modified), Revoked (access removed)
- Documentation: All decisions recorded with reviewer name, date, decision, and rationale

8.2 Q1 & Q2 2026 Review Outcomes

Two complete quarterly review cycles have been executed since the IAM lab deployment. Key findings and outcomes:

- Q1 2026 — 10 accounts reviewed. 9 Certified, 1 Revised: EXT-ClearPath (vendor) access scope reduced from 2 SharePoint site collections to 1 following discovery of unnecessary access (INC-0118).
- Q2 2026 — 12 accounts reviewed (added new accounts). All 12 Certified. PIM roadmap noted for Global Admin role in reviewer comments.
- 100% SLA compliance across both review cycles — all reviews completed within the scheduled review window.

8.3 Automated Review Roadmap (Entra ID P2)

When Entra ID P2 is activated, the manual review process will be replaced with Microsoft Entra ID Access Reviews, which provides:

- Automated review campaigns triggered quarterly for specific groups and roles
- Self-attestation workflows where users certify their own access needs
- Manager-driven reviews with automated access removal for non-responses (deny by default)
- Integration with PIM for just-in-time review of privileged role activations

9. Risk Findings & Security Posture Assessment

The following security findings were identified during the IAM lab implementation and review. Each finding is categorized by severity (Critical / High / Medium / Low / Informational), mapped to relevant regulatory frameworks, and assigned a remediation recommendation.

ID	Finding	Severity	HIPAA / NIST Reference	Current State	Recommendation
F-001	Global Administrator assigned as permanent — not time-limited	HIGH	NIST 800-53 AC-6; HIPAA §164.308(a)(3)	1 permanent Global Admin (m.chen). No PIM activation.	Implement Privileged Identity Management (PIM) — requires P2 license. Target Q3 2026.
F-002	Conditional Access policy CA-003 in Report-Only mode	MEDIUM	NIST SP 800-207 §3.3; CIS Control 6.5	Compliant device policy is not enforced — report-only pending device enrollment.	Complete Intune enrollment for all privileged users. Enable policy enforcement Q3 2026.
F-003	Risk-based Conditional Access (CA-005) not yet active	MEDIUM	NIST 800-53 SI-4; HIPAA §164.308(a)(1)	CA-005 requires Entra ID P2 license (Identity Protection). Not currently licensed.	Include P2 licensing in FY2027 IT budget. Document as accepted risk in interim period.
F-004	External vendor (EXT-ClearPath) previously had access to 2 SharePoint sites	MEDIUM	HIPAA §164.314(a)(1) — Business Associate; CIS Control 6.7	Remediated in Q1 2026 Access Review (INC-0118). Scoped to 1 site.	Formalize vendor access scoping in Business Associate Agreement. Quarterly re-validation.
F-005	No Single Sign-On (SSO) federation for on-prem applications	LOW	NIST SP 800-207 §2; CIS Control 6.3	Entra ID covers cloud apps only. On-prem applications use separate credential stores.	Evaluate Entra ID Connect (Hybrid Identity) or SAML federation for on-prem apps in FY2027.
F-006	MFA enrollment confirmed for all users — Security Defaults active	INFO	HIPAA §164.312(d); NIST 800-63B AAL2	All 8 member accounts enrolled. Security Defaults enabled as baseline MFA enforcement.	Transition from Security Defaults to Conditional Access-based MFA when P1 is activated.

9.1 Overall Security Posture

The current security posture for Meridian Health Group's IAM environment is assessed as Foundational — Zero Trust Level 1 (Initial), based on the CISA Zero Trust Maturity Model. The implementation addresses the baseline identity controls required by HIPAA and NIST CSF. The primary gaps are in the Optimal tier — specifically PIM, Identity Protection, and automated access reviews — all of which require P2 licensing.

Posture Summary: Zero Trust Maturity Level Assessment

Level 1 — Traditional (baseline met): MFA enforced, basic RBAC implemented | Level 2 — Advanced (in progress): Conditional Access policies active, geo-restriction enabled, CA-003 in report-only | Level 3 — Optimal (roadmap): PIM, Identity Protection, Intune compliance enforcement, automated access reviews

10. Recommendations & Licensing Roadmap

The following prioritized recommendations represent the roadmap to achieving full Zero Trust maturity for Meridian Health Group's IAM environment. Recommendations are sequenced by priority and organized by required licensing tier.

Priority	Recommendation	Timeline	License Req.	Owner	Cost Impact
P1 — CRITICAL	Activate Privileged Identity Management (PIM) for Global Admin and Privileged Role Admin — eliminate permanent assignment	Q3 2026	Entra P2	IT Admin	P2 License
P1 — HIGH	Complete Intune device enrollment for SG-ITAdmins, SG-SecurityOps, SG-Executives — enable CA-003 enforcement	Q3 2026	Intune Plan 1	IT Admin	Intune License
P2 — HIGH	Activate Identity Protection (CA-005) — risk-based Conditional Access for all users	Q4 2026	Entra P2	SecOps	P2 License
P2 — MEDIUM	Transition from Security Defaults to named Conditional Access policies when P1 is acquired	Q3 2026	Entra P1	IT Admin	P1 License
P3 — MEDIUM	Implement Entra ID Connect for hybrid identity (on-prem AD synchronization)	FY2027	Entra P1 + Server	IT Admin	Infrastructure
P3 — MEDIUM	Formalize Business Associate Agreements for all vendor accounts (B2B guests)	Q3 2026	None	Compliance	Legal Counsel
P4 — LOW	Evaluate Microsoft Sentinel integration for unified SIEM with Entra ID sign-in alerts	FY2027	Sentinel	SecOps	SIEM License
P4 — LOW	Deploy Entra ID Access Packages for automated access request and approval workflows	FY2027	Entra P2	IT Admin	P2 License

10.1 Licensing Upgrade Path

Immediate (Current — Free Tier): Security Defaults active. All 7 CA-007 and foundational policies implemented. RBAC, access reviews, JML workflow operational.

Phase 1 — Entra ID P1 (Q3 2026): Enable named Conditional Access policies replacing Security Defaults. Activate CA-001 through CA-004 and CA-006. Enable CA-003 enforcement after Intune enrollment. Estimated cost: ~\$6/user/month (included in M365 E3).

Phase 2 — Entra ID P2 (Q4 2026 / FY2027): Activate Privileged Identity Management (PIM) for all privileged roles. Enable Identity Protection (CA-005 risk-based policies). Automate quarterly access reviews via Entra ID Access Reviews. Estimated cost: ~\$9/user/month incremental from P1.

11. Conclusion

This report documents the complete Zero Trust Identity and Access Management implementation for Meridian Health Group, built on Microsoft Entra ID and aligned to NIST SP 800-207, HIPAA Security Rule, and CIS Controls v8.

The implementation establishes a robust identity security foundation: 10 accounts provisioned with appropriate roles and group memberships, MFA enforced for all users via Security Defaults, Conditional Access policies covering geo-restriction, legacy authentication blocking, vendor access controls, and service account protections. A documented JML workflow with 100% SLA compliance and a completed two-cycle quarterly access review program demonstrate operational maturity in identity governance.

The primary gap in reaching full Zero Trust maturity is the Entra ID P1/P2 license requirement for Conditional Access enforcement, Privileged Identity Management, and automated access reviews. The roadmap outlined in Section 10 provides a clear, phased path to achieving Zero Trust Level 3 (Optimal) maturity within FY2027.

I, Maximilian Rivera, Information Security Analyst, certify that the IAM controls, configurations, role assignments, and findings documented in this report accurately reflect the state of the Meridian Health Group Microsoft Entra ID tenant as of June 2026. All configurations were implemented following the principle of least privilege and in alignment with the regulatory frameworks cited herein.

Appendix A — Glossary of Terms

Term	Definition
Conditional Access (CA)	An Entra ID policy engine that enforces access decisions based on identity, device, location, and risk signals. Requires Entra ID P1.
HIPAA	Health Insurance Portability and Accountability Act. Federal law requiring safeguards for Protected Health Information (PHI). Security Rule: 45 CFR §164.
IAM	Identity and Access Management — the framework of policies and technologies ensuring that the right users access the right resources at the right time.
JML	Joiners-Movers-Leavers — the process governing identity lifecycle events: onboarding (Joiner), role change (Mover), and offboarding (Leaver).
Least Privilege	A security principle requiring that users are granted only the minimum access rights necessary to perform their job function.
MFA	Multi-Factor Authentication — authentication requiring two or more verification factors (something you know + something you have/are).
NIST SP 800-207	NIST Special Publication 800-207 — Zero Trust Architecture. Defines seven tenets of Zero Trust and guidance for federal and commercial implementations.
PHI	Protected Health Information — individually identifiable health information protected by HIPAA.
PIM	Privileged Identity Management — Entra ID P2 feature providing just-in-time, time-limited, and audited activation of privileged roles.
RBAC	Role-Based Access Control — an access control model where permissions are assigned to roles, and users are assigned to roles based on job function.
Security Defaults	A set of pre-configured Entra ID security settings providing baseline MFA enforcement, legacy auth blocking, and admin MFA. Free tier feature.
Tenant	A dedicated instance of Microsoft Entra ID containing an organization's identities, policies, and resources.
Zero Trust	A security model that eliminates implicit trust — every access request is authenticated, authorized, and continuously validated regardless of network location.

Appendix B — Regulatory Control Mapping

The following table maps specific IAM controls implemented in this project to applicable regulatory requirements:

HIPAA Control	NIST CSF 2.0	CIS Control v8	IAM Implementation
§164.308(a)(3) Workforce Security	PR.AC-1, PR.AC-4	CIS 5 — Account Mgmt	RBAC + least privilege + JML workflow
§164.312(a)(2) User Authentication	PR.AA-01, PR.AA-02	CIS 6 — Access Control	MFA via Security Defaults; SSPR enabled
§164.312(d) Person Authentication	PR.AA-03	CIS 6.3 — MFA Required	MFA enforced for all member accounts
§164.308(a)(1) Risk Analysis	ID.RA-01	CIS 18 — Penetration Testing	Risk findings documented in Section 9
§164.308(a)(5) Security Training	PR.AT-01	CIS 14 — Security Awareness	Access review process documented for staff
§164.312(b) Audit Controls	DE.CM-01, DE.CM-03	CIS 8 — Audit Log Mgmt	Entra ID audit + sign-in logs; Purview retention
§164.308(a)(4) Access Management	PR.AC-3, PR.AC-6	CIS 6.7 — Access Revocation	Leaver process ≤4h disable; quarterly access reviews
§164.314(a)(1) BAA	GV.RM-06	CIS 15 — Service Provider Mgmt	B2B guest (ClearPath) scoped + ToU enforced (CA-006)

— End of Document —